

Travel AI Governance — PoC Brief

What the client needs. What Connector delivers. What I will build.

What I Understood

- Travel platform uses AI for search, booking recommendations, and CRM — all live and customer-facing
- Every AI interaction today is a disposable log — no governance, no enforcement, no chain of custody
- If a regulator asks “why did your AI suggest this?” — they cannot answer that today
- User consent exists but is **not enforced** at AI execution time — it is a database field, not a gate
- High-value bookings have no human review step — AI acts unilaterally regardless of amount
- They want a **sidcar** — nothing ripped, nothing replaced, governance runs alongside
- Must be AWS-native — everything in their own account, no SaaS data exposure
- The PoC deliverable is two files: `traveler_profile.md` and `trip_details.md` — compiled from governed event history
- The real long-term value is warm-start personalisation

— AI remembers context across sessions

- GDPR, CCPA, and EU AI Act (Aug 2025) make this a legal requirement, not just a nice-to-have

What I Can Deliver

Capture API — REST endpoint that ingests search and booking events from their Python/Node app

3 Live Policies — consent check, \$5K booking threshold → HITL, PII field redaction

Tamper-evident audit chain — every decision CID-addressed, Ed25519 signed, append-only

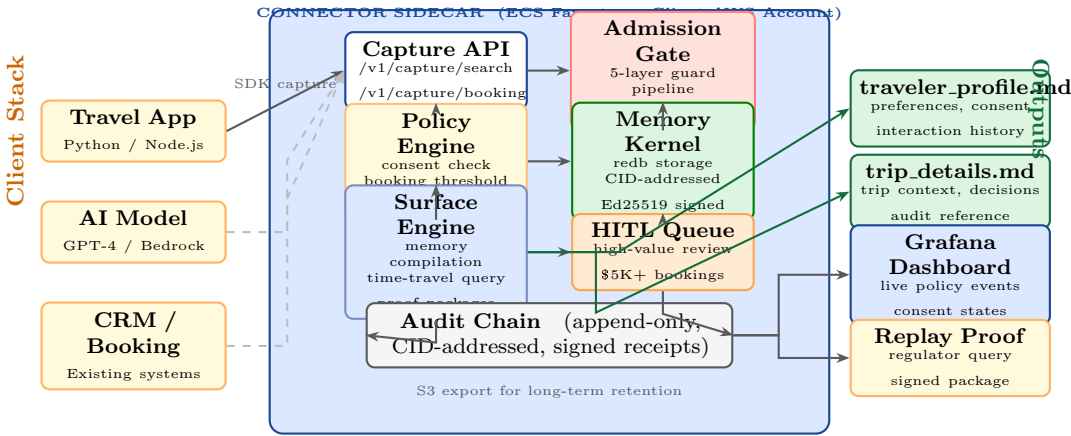
Memory compilation — governed events compiled into structured `.md` profile files

Replay demo — given user ID + date, produce signed proof of what AI saw and decided

Grafana dashboard — live policy decisions and audit events via webhook

Terraform deploy — one-command setup in their AWS account (ECS Fargate)

PoC Architecture — Connector as Governance Sidcar



Timeline: 8 weeks Compute: ECS Fargate 1vCPU / 2GB / ~\$50/mo Storage: redb (Event+SQL Engine) + S3 (OS) Rust | AWS-native | No data leaves client account